

OpenZeppelin
Security Audit: Sample Protocol
Date: 2024-09-15
Audited by: Alice (lead), Bob, Carol

Executive Summary

This is a synthetic OpenZeppelin-style audit report used for testing.

Findings

[H-01] Reentrancy in withdraw enables fund theft

Description

The withdraw function in contracts/Vault.sol:42 transfers ERC-777 tokens before updating internal accounting. An attacker re-enters withdraw via the token hook to drain the vault.

Recommendation

Apply the checks-effects-interactions pattern: update internal balances before the external token transfer, or add a nonReentrant guard from OpenZeppelin's ReentrancyGuard mixin.

Resolution: Fixed in PR #1234